

1. Explain Active Directory (AD)

Active Directory (AD) is a directory service developed by Microsoft for managing users, computers, groups, and resources in a Windows network.

Key Components

- **Domain** – A collection of users, computers, and policies.
- **Domain Controller (DC)** – A server that authenticates users and enforces security policies.
- **Organizational Unit (OU)** – Used to organize users and computers.
- **Group Policy (GPO)** – Applies security settings and configurations across systems.
- **LDAP** – Protocol used to query directory information.
- **Kerberos** – Default authentication protocol in AD.

Benefits

- Centralized user management
 - Single Sign-On (SSO)
 - Access control and permissions
 - Security policy enforcement
-

2. Common Active Directory Attacks

Pass-the-Hash (PtH)

- Attacker steals password hashes from memory.
- Uses hashes to authenticate without knowing the actual password.

Kerberoasting

- Attacker requests service tickets for service accounts.
- Extracts ticket hashes and cracks them offline to recover passwords.

AS-REP Roasting

- Targets accounts with Kerberos pre-authentication disabled.
- Obtains encrypted authentication data and cracks it offline.

Pass-the-Ticket (PtT)

- Steals Kerberos tickets from memory.
- Reuses them to access resources.

Golden Ticket Attack

- Attacker compromises the KRBTGT account.
- Creates forged Kerberos tickets with any privileges.

Silver Ticket Attack

- Creates forged service tickets for specific services.
- Does not require contacting the Domain Controller.

DCSync Attack

- Attacker impersonates a Domain Controller.
- Requests password hashes from AD replication services.

LDAP Enumeration

- Collects information about users, groups, and systems.
- Used for reconnaissance before further attacks.

Password Spraying

- Tries a few common passwords against many accounts.
 - Avoids account lockouts.
-

3. Privilege Escalation Scenario Analysis

Scenario

An attacker gains access to a standard employee account through phishing.

Attack Path

- 1. Initial Access**
 - User enters credentials on a fake login page.
 - Attacker obtains domain credentials.
- 2. Enumeration**
 - Uses tools to identify users, groups, and service accounts.
 - Finds a service account with a weak password.
- 3. Kerberoasting**
 - Requests a Kerberos service ticket.
 - Cracks the ticket offline and recovers the service account password.
- 4. Privilege Escalation**
 - Service account is a member of a privileged group.
 - Attacker gains administrative access.
- 5. Domain Compromise**
 - Extracts additional credentials.
 - Performs DCSync or Golden Ticket attack.
 - Gains control of the entire domain.

Indicators of Compromise (IoCs)

- Unusual Kerberos ticket requests
- Multiple failed logins

- Unexpected privilege changes
- Suspicious LDAP queries
- Unauthorized account creation

Mitigations

- Enforce strong passwords and MFA
- Use least-privilege access
- Monitor Kerberos activity
- Protect service accounts
- Regularly audit privileged groups
- Deploy EDR/XDR solutions
- Disable unnecessary administrative rights